

Introduction to Information-Flow Security

Narendra Kumar Nelabhotla (Naren)

naren.nelabhotla@tcs.com

Scenario

User

Service Provider

Sensitive data

Application

- Mutually mistrusting parties need to collaborate
- **Example:** User (*taxpayer*) wants to compute (*tax*) on his sensitive data (*financial data*) using an application (*tax-calculator*) provided by a service provider (*CA*)
 - *CA* wants to protect the confidentiality of the *tax-optimization-rules* embedded in the *tax-calculator*
 - *taxpayer* wants to protect the confidentiality of his *financial data*

Agenda

- **Aspects of Security**
 - Access Controls and their Limitations
 - Covert Channels and the Confinement Problem
 - Duality of Confidentiality and Integrity
 - Practical Considerations
- **Information-Flow Security (IFS) Models**
 - Data Mark Machine
 - Lattice Model
 - Non-Interference
 - Decentralized Information-Flow Control
- **IFS Systems in Labs**

Aspects of Security

Access Controls and their Limitations (1)

- *Scenario:* user 'X' downloads a useful application 'A' from the internet and executes it
- Application 'A' inherits all the privileges of 'X' !!
- In particular, 'A' can read a file (protection – 400) containing sensitive information (say passwords) and make an unprotected copy of it (protection – 444) that all the users of the system can access, or worse, export the information out of the computer system !!
 - All of this **WITHOUT VIOLATING THE ACCESS CONTROLS**
- **TRIVIA:** Applications such as 'A' are referred to as **TROJAN HORSE**

Access Controls and their Limitations (2)

- All access control models (including RBAC) are prone to indirect information leakages exemplified in the scenario
- It is **undecidable** whether an arbitrary access-matrix model is **safe**, that is, whether a subject could get unauthorized access to an object

Michael A. Harrison, Walter L. Ruzzo, and Jeffrey D. Ullman. "Protection in operating systems". Communications of the ACM 19, 8 (1976), 461–471. <https://doi.org/10.1145/360303.360333>

- **Diagnosis:**
 - Access controls were originally derived for protection of shared resources (hardware – such as pages, memory segments, registers etc.) primarily by an Operating System
 - The same concepts have been extrapolated to derive protection mechanisms for a variety of systems such as filesystems, networks, extending all the way to distributed systems

Covert Channels and the Confinement Problem

- **Confinement problem**: prevent a server from leaking information that the user of the service considers confidential
- **Laws of confinement**
 - Total isolation
 - Transitivity
 - Masking
 - Enforcement
- **Channels for information transmission**
 - Legitimate channel
 - Covert channel

Butler W. Lampson. 1973. “A note on the confinement problem”.
Communications of the ACM 16, 10 (Oct. 1973), 613–615.
<https://doi.org/10.1145/362375.362389>

Confidentiality

D. E. Bell and L. J. La Padula,

"Secure Computer Systems: Mathematical Foundations,"
Technical Report ESD-TR-73-278-I, MITRE Corp., 1973.

- Users and files are assigned **labels** made up of confidentiality classes (ordered, public/secret/top secret) and categories (need-to-know, defense/air force/navy)
- A user with 'secret' clearance can access (read) a 'public' file but not a 'top secret' file **Simple-security property (no-read-up)**
- A user with 'secret' clearance can write to a 'top secret' file but not a 'public' file ***-security property (no-write-down)**
- **Basic-Security Theorem:** A system is **secure** if it always follows the simple-security property and the *-security property

Integrity

K. J. Biba. "Integrity Considerations for Secure, Computer Systems".
Technical Report ESD-TR-76- 372, MITRE Corp., 1977.

- Users and files are assigned **labels** made up of trustworthiness classes (ordered, low/medium/high) and categories (need-to-know, defense/air force/navy)
- A user with 'medium' trustworthiness can access (read) a 'high' trustworthy file but not a 'low' trustworthy file
Simple-security property (no-read-down)
- A user with 'medium' trustworthiness can write to a 'low' trustworthy file but not a 'high' trustworthy file
***-security property (no-write-up)**
- A system is **secure** if it always follows the simple-security property and the *-security property
- Low-watermark policy: allows for dynamic labels to users

Duality of Confidentiality and Integrity

- It is important to control both reading and writing for preserving confidentiality/integrity
- Information must flow only upwards for preserving confidentiality, while it must flow only downwards for preserving integrity
- It is too restrictive in practice to assign fixed labels to users and files
- Most practical applications need to simultaneously achieve confidentiality and integrity !!

Practical Considerations (1)

- Decrease the confidentiality level of information – **Declassification**
- Increase the trustworthiness of information – **Endorsement**
- In practice systems become too restrictive without the ability to declassify and endorse
- Traditionally declassification and endorsement are supported through **'trusted'** entities that are not subject to security restrictions
- McLean demonstrated the perils of combining label change operations with regular operations – **tranquility principle**

John McLean, "A comment on the 'basic security theorem' of Bell and LaPadula,"
Information Processing Letters, Volume 20, Issue 2, 1985
Pages 67-70, [https://doi.org/10.1016/0020-0190\(85\)90065-1](https://doi.org/10.1016/0020-0190(85)90065-1)

Practical Considerations (2)

**Department of Defense, DoD 5200.28-STD, 1983
"Trusted Computer System Evaluation Criteria"**

- Trusted Computer System Evaluation Criteria (TCSEC – Orange Book) is a precursor to today's [Common Criteria](#) for IT Security Certification
 - TCSEC based on gradations of multi-level security supported by a computer system
 - TCSEC was never fully adopted because computer systems could not simultaneously provide functionality, speed, convenience and security !!

**Butler Lampson. 2011. "Making untrusted code useful: technical perspective."
Communications of the ACM 54, 11 (November 2011), 92.
<https://doi.org/10.1145/2018396.2018418>**

Other Important Models

- The Chinese Wall Security Policy

D. F. C. Brewer and M. J. Nash, "The Chinese Wall security policy,"
IEEE Symposium on Security and Privacy, 1989, pp. 206-214
DOI: 10.1109/SECPRI.1989.36295.

- Clark-Wilson Model for Integrity

D. D. Clark and D. R. Wilson, "A Comparison of Commercial and Military Computer Security Policies,"
IEEE Symposium on Security and Privacy, 1987, pp. 184-184
DOI: 10.1109/SP.1987.10001.

- and many many more ...

Information-Flow Security (IFS) Models

Data Mark Machine

J. S. Fenton. "Memoryless subsystems"

The Computer Journal, Volume 17, Issue 2, 1974, pp 143–147

<https://doi.org/10.1093/comjnl/17.2.143>

- Two-valued data mark: **null** / **priv**

$$\begin{aligned}
 x' & \quad \underline{\text{if } x = M(x, p) \text{ then } x := x + 1 \text{ fi}} \\
 x^-(n) & \quad \underline{\text{if } x = \emptyset \text{ then } (\text{if } p = M(x, p) \text{ then } \underline{\text{goto } n} \text{ fi})} \\
 & \quad \quad \underline{\text{else } (\text{if } x = M(x, p) \text{ then } x := x - 1 \text{ fi}) \text{ fi}} \\
 x^*(n) & \quad \underline{\text{if } x = \emptyset \text{ then } (\text{stack}(p, p); p := M(x, p); \underline{\text{goto } n})} \\
 & \quad \underline{\text{else } (\text{if } x = M(x, p) \text{ then } x := x - 1 \text{ fi}) \text{ fi}} \\
 \text{Return} & \quad p, p := \text{unstack}() \\
 \text{Halt} & \quad \underline{\text{if } p = \text{null} \text{ then } \underline{\text{halt}} \text{ fi}}
 \end{aligned}$$

Minsky Machine (1967)

- Two infinite registers
- A Zero register
- Three instructions
 - a'
 - $a^-(n)$
 - halt

Theorem: Suppose the machine started with **p** = **null** and that it has halted. Then the system is secure.

Lattice Model (1)

Dorothy E. Denning. "A lattice model of secure information flow".
Communications of the ACM 19, 5 (1976), 236–243
<https://doi.org/10.1145/360051.360056>

- Information flow intuitions
 - $a = a$ is this statement secure? (**Reflexive**)
 - Suppose $a = b$ is secure, and $b = a$ is secure (**Anti-symmetric**)
 - Suppose $b = a$ is secure, and $c = b$ is secure; is $c = a$ secure? (**Transitive**)
 - When is $c = f(a, b)$ secure? (**least upper bound**)
 - $a = 5$ is this statement secure? (**lower bound**)

Lattice Model (2)

- An *information flow model FM* is defined by $\langle S, O, SC, \rightarrow, \oplus, \perp \rangle$
 - S – set of subjects (active entities whose actions result in information flow)
 - O – set of objects (passive information containers)
 - SC – set of security classes (finite, disjoint)
 - $\rightarrow$ – can-flow-to relationship
 - $\oplus$ – class-combining operator (associative, commutative)
 - $\perp$ – lowest information class
- A flow model FM is **secure** if and only if execution of a sequence of operations cannot give rise to a flow that violates the relation ' $\rightarrow$ '
- Transitivity of ' $\rightarrow$ ' implies that **security composes!!!**

J. A. Goguen and J. Meseguer, "Security Policies and Security Models,"
 IEEE Symposium on Security and Privacy, 1982, pp. 11-20
 DOI: 10.1109/SP.1982.10014.

Non-Interference

- System Model = Capability System (M)
 - **Sets:** Users, States, State Commands, Outputs, Capability Tables, Capability Commands
 - **Functions:** out, do, cdo
 - **Constants:** t0, s0
- Non-interference: M – state machine, G, G' – sets of users, A – ability
 - $G :| G'$ iff $\forall w \in (U \times C)^*, u \in G' \quad [[w]]_u = [[p_G(w)]]_u$
 - $A :| G'$ iff $\forall w \in (U \times C)^*, u \in G' \quad [[w]]_u = [[p_A(w)]]_u$
 - $G, A :| G'$ iff $\forall w \in (U \times C)^*, u \in G' \quad [[w]]_u = [[p_{G,A}(w)]]_u$
- **Security Policy** = set of non-interference assertions
- Captures – MLS, Isolation, Channel control, information-flow

Decentralized IFC (1)

Andrew C. Myers and Barbara Liskov.

“A decentralized model for information flow control”

SOSP, 1997, pp. 129–142. DOI: 10.1145/268998.266669

- Moves away from centralized authority specifying policy and provides each user the ability to (i) **define information flow policy** at the level of individual data items, and (ii) **declassify** his own data
 - provides better security when using downloaded applications
- Label L
 - Set of owners – $owners(L)$
 - Set of readers for each owner – $readers(L, O)$
- **Definition of $L_1 \sqsubseteq L_2$**

$$owners(L_1) \subseteq owners(L_2)$$

$$\forall O \in owners(L_1), readers(L_1, O) \supseteq readers(L_2, O)$$

Decentralized IFC (2)

- **Labels for Derived Values (Definition of $L_1 \sqcup L_2$)**

$$\begin{aligned} \text{owners}(L_1 \sqcup L_2) &= \text{owners}(L_1) \cup \text{owners}(L_2) \\ \text{readers}(L_1 \sqcup L_2, O) &= \text{readers}(L_1, O) \cap \text{readers}(L_2, O) \end{aligned}$$

- Relabeling Rules

1. **Restriction:** A relabeling from L_1 to L_2 is valid if it is a restriction
2. **Declassification:** A declassification either adds readers for some owner O or removes the owner O . This relabeling can be done only if the process acts for O

Other important models (1)

- **Decentralized Label Model**

Andrew C. Myers and Barbara Liskov. “Protecting privacy using the decentralized label model”. ACM Trans. Softw. Eng. Methodol. 9, 4, 2000, pp. 410–442. DOI: 10.1145/363516.363526

- **Disjunction Category Labels**

Deian Stefan, Alejandro Russo, David Mazières, and John C. Mitchell. “Disjunction category labels”. Nordic conference on Information Security Technology for Applications, 2011, pp. 223–239. DOI: 10.1007/978-3-642-29615-4_16

Other important models (2)

- **Non-deducibility**

D. Sutherland. "A Model of Information". National Computer Security Conference, 1986, pp. 175-183

- **Non-Influence**

von Oheimb, D. "Information Flow Control Revisited: Noninfluence = Noninterference + Nonleakage". ESORICS, 2004, pp. 225-243. DOI: 10.1007/978-3-540-30108-0_14

- ...

IFS Systems in Labs

IFS Systems in Labs (1)

- Language based security
 - JIF – <https://www.cs.cornell.edu/jif/>
 - Jflow – <https://pmg.csail.mit.edu/jflow/>
 - Laminar – <https://z.cs.utexas.edu/users/osa/laminar/>
 - FlowCAML – <http://cristal.inria.fr/~simonet/soft/flowcaml/>
 - SecVerilog – <https://www.cs.cornell.edu/projects/secverilog/>
- Operating Systems
 - Asbestos – <http://asbestos.cs.ucla.edu/>
 - HiStar – <https://www.scs.stanford.edu/histar/>
 - Laminar – <https://z.cs.utexas.edu/users/osa/laminar/>
 - Flume – <http://flume.csail.mit.edu/>

IFS Systems in Labs (2)

- Databases
 - IFDB – https://pmg.csail.mit.edu/aeolus/schultz13_ifdb_decentralized_ifc-abstract.html
- Web browsers
 - FlowFox – <http://distrinet.cs.kuleuven.be/software/FlowFox/>
- Distributed systems
 - Fabric – <https://www.cs.cornell.edu/projects/fabric/>
 - Aeolus – <https://pmg.csail.mit.edu/aeolus/>

Thank you